# THREAT INTELLIGENCE CAPSTONE REPORT

**Project Title:** Threat Actor Profiling and Risk Assessment for Novacore Financial Services

**Case Study Organization:** Novacore Financial Services

**Assumed Region of Operation:** United Kingdom/European Economic Area

**Selected Threat Group:** Scattered Spider *(UNC3944 / 0ktapus)*

**Analyst Name:** Qhubekani Luphahla

**Role:** Threat Intelligence Analyst

**Cohort:** April 2026

**Submission Date:** 17 July 2026

## TABLE OF CONTENTS

1. Executive Summary
2. Project Introduction
3. Novacore Threat Profile
4. Intelligence Requirements
5. Threat Group Profiles
6. Threat Group Comparison
7. Selected Threat Group Deep Dive
8. Famous Attack Case Study
9. Recent Publicly Reported Attack or Campaign
10. Risk Assessment for Novacore
11. Recommendations
12. Conclusion
13. References
14. Appendices

## 1. EXECUTIVE SUMMARY

This project assesses risks facing Novacore Financial Services by researching and analysing financially motivated cyber threat groups active in the United Kingdom and EU threat trends. Novacore is assumed to operate across the UK, delivering payment processing and digital wallet services to small and medium-sized businesses. The five leading threat groups profiled included:

1. Scattered Spider
2. BlackCat/ALPHV.
3. FIN7.
4. TA551 (Shathak).
5. LockBit 3.0.

**Scattered Spider** was selected as the most relevant threat, as it specialises in targeting cloud-native fintech and payment providers, has confirmed high activity across the UK financial services, and uses attack methods that match Novacore's technology and working patterns.

The primary risk identified is successful ***credential theft and unauthorised access,*** which can lead to customer data loss, payment fraud, ransomware deployment, regulatory penalties, and serious reputational harm. The most critical recommendation is to ***roll out phishing-resistant multi factor authentication alongside strict identity verification for all account and access changes.***

## 2. PROJECT INTRODUCTION

This project applies structured threat intelligence methods to ***identify, evaluate, and prioritise cyber threats*** facing Novacore Financial Services. The goal is to ***produce evidence-based insights*** that helps security teams understand ***who*** may target the organisation, ***how*** they operate, and what defensive actions will provide the strongest protection.

Novacore Financial Services is a mid-sized fintech company that provides secure online payment processing, digital wallet platforms, business onboarding services, and associated support. The organisation stores and processes high-value regulated data including customer personal details, payment card information, bank account records, transaction histories, and business verification documents. For this assessment, Novacore is assumed to operate primarily within the United Kingdom, with services and compliance aligned to UK law and financial sector standards.

Financial technology companies like Novacore are highly attractive to financially motivated threat actors for several reasons:

- they hold large volumes of directly monetizable financial data
- they operate systems that process or move funds
- they are subject to strict privacy and security rules that increase pressure to pay ransoms or avoid breaches
- and mid-sized operators often have less mature security defences than major high-street banks.

## 3. NOVACORE THREAT PROFILE

### Business Profile

| Area | Description |
|---|---|
| **Organisation** | Novacore Financial Services |
| **Industry** | Financial Technology/Digital Payments |
| **Assumed Region** | United Kingdom |
| **Key Services** | Online payment processing, digital wallet hosting, merchant account management, SME business onboarding and verification. |
| **Sensitive Data Held** | Customer personal data, payment instrument details, account credentials, transaction records, merchant financial information and identify verification documentation. |

### Threat Exposure

Novacore faces exposure to common and advanced threats including:

- Phishing and social engineering targeting staff, customers, and support teams
- Credential theft and unauthorised account access
- Malware and information stealer deployment
- Ransomware and data extortion
- Payment system manipulation and transaction fraud
- Business Email Compromise (BEC) and invoice fraud
- Brand impersonation and customer-facing scams
- Third-party and supply chain risks

## 4. INTELLIGENCE REQUIREMENTS

This research was guided by the following core intelligence questions:

1. Which financially motivated threat groups actively target financial institutions, fintech, and payment providers?
2. Which of these groups have confirmed activity or targeting interest in the United Kingdom and wider European region?
3. Which groups use techniques such as phishing, credential theft, malware deployment, and ransomware that are relevant to Novacore's risk profile?
4. Which groups specifically target payment processing infrastructure, digital services, or cloud environments used by modern fintech?
5. Which single threat group represents the and highest-impact risk to Novacore?
6. What defensive measures and monitoring controls should Novacore prioritise based on the most relevant threat group's behaviour?

## 5. THREAT GROUP PROFILES

### Threat Group 1: Scattered Spider

| **Filed** | **Response** |
|---|---|
| Threat Group | Scattered Spider |
| Known Aliases | UNC3944, 0ktapus, Opal Ring |
| Motivation | Financial gain through credential theft, sale of network access, and partnership with ransomware operators for extortion. |
| Common Targets | Fintechs, payment processors, cloud service providers, telecommunications firms, SaaS platforms, and technology companies |
| Regional Relevance | **High** Confirmed sustained activity targeting UK financial services since 2023; cited in multiple public alerts from the UK NCSC and Financial Conduct Authority (FCA) |

| | |
|---|---|
| Known Tools/Malware | Evilginx2, custom phishing kits, Lumma Stealer, Rhadamanthys, legitimate remote administration tools, living-off-the-land scripts |
| Prominent TTPs | SMS and email phishing; MFA bypass techniques; social engineering of IT helpdesks; use of stolen valid credentials; lateral movement via legitimate tools; staging data for third-party ransomware deployment |
| MITRE ATT&CK Mapping | T1566.001 Phishing: Spear phishing Link T1556.004 Modify Authentication Process: MFA Bypass<br><br>T1078 Valid Accounts<br><br>T1021.002 Remote Services: SMB/Windows Admin Shares<br><br>T1486 Data Encrypted for Impact |
| Why it Matters to Novacore | It is one of very few groups that designs operations specifically for cloud-native fintechs and payment providers and uses methods that directly target gaps common to mid-sized UK organisations. |

**Threat Group 2: BlackCat / ALPHV**

| **Field** | **Response** |
|---|---|
| Threat Group | BlackCat/ALPHV |
| Known Aliases | ALPHV |
| Motivation | Financial extortion using double and triple extortion models |
| Common Targets | Financial institutions, payment processors, critical infrastructure, legal firms, and organisations with high regulatory exposure |

| | |
|---|---|
| Regional Relevance | **High:** Confirmed intrusions at UK financial and payment firms; active across all major European markets |
| Known Tools/Malware | ALPHV ransomware, custom information stealers, Cobalt Strike, AnyDesk, TeamViewer |
| Prominent TTPs | Initial access via exploited public applications or purchased credentials; mass data exfiltration before encryption; public leak site disclosure; applying pressure via regulators or media |
| MITRE ATT&CK Mapping | T1190 Exploit Public-Facing Application T1003 Credential Dumping T1486 Data Encrypted for Impact T1487 Data Destruction T1202 Indirect Victimisation |
| Why it Matters to Novacore | They have a potential cause severe financial and reputational harm if access is gained, though it is generally less targeted at mid-sized fintechs than Scattered Spider. |

**Threat Group 3: FIN7**

| **Field** | **Response** |
|---|---|
| Threat Group | FIN7 |
| Known Aliases | Carbanak Group, Cobalt Group |
| Motivation | Direct theft of payment card data and financial records for resale or fraudulent use |
| Common Targets | Payment processors, merchant services, retail and hospitality networks, point-of-sale systems, financial institutions |
| Regional Relevance | **Medium**: Long history of targeting UK payment infrastructure; recently increased activity against smaller fintech operators |
| Known Tools/Malware | BazarLoader, Cobalt Strike, point-of-sale memory scrapers Carbanak malware. |

| | |
|---|---|
| Prominent TTPs | Spear phishing with malicious attachments; compromise of third-party suppliers to reach targets; long-term persistence; targeted extraction of transaction data |
| MITRE ATT&CK Mapping | T1584.007 Compromise Third-Party Infrastructure T1040 Exfiltration Over Network Medium T1490 Inhibit System Recovery |
| Why it Matters to Novacore | Has deep experience targeting payment systems but generally focuses on organisations with established transaction volumes rather than newer mid-sized fintechs. |

**Threat Group 4: TA551 (Shathak)**

-

| **Field** | **Response** |
|---|---|
| Threat Group | TA551 |
| Known Aliases | Shathak |
| Motivation | Revenue from malware distribution commissions and sale of compromised network access |
| Common Targets | Financial services, accounting firms, insurance providers, professional services across Europe. |
| Regional Relevance | **High:** Very high-volume phishing campaigns targeting UK financial sector staff since 2022. |
| Known Tools/Malware | Ursnif/Gozi, Qakbot, Cobalt Strike, malicious macro documents |
| Prominent TTPs | Mass phishing using fake invoices and payment alerts; payload delivery via compressed files; resale of access to higher-tier threat operators |
| MITRE ATT&CK Mapping | T1566.003 Phishing via Service, T1204.002 User Execution: Malicious File T1027 Obfuscated Files or Information T1567 Exfiltration Over Web Service |

| | |
|---|---|
| Why it Matters to Novacore | Frequently targets UK finance staff but uses broad opportunistic campaigns rather than targeted fintech operations. |

**Threat Group 5: LockBit 3.0 / LockBit Black**

| **Field** | **Response** |
|---|---|
| Threat Group | LockBit 3.0 / LockBit Black |
| Known Aliases | LockBit |
| Motivation | Rapid, scalable financial extortion via ransomware |
| Common Targets | All sectors; prioritises organisations with limited security maturity and high operational or financial impact |
| Regional Relevance | **High:** Listed by the NCSC as one of the most common ransomware threats affecting UK organisations; confirmed incidents in UK fintech |
| Known Tools/Malware | LockBit ransomware variants, custom credential stealers, Mimikatz, PsExec. |
| Prominent TTPs | nitial access via stolen credentials or unpatched public services; rapid lateral movement; fast system encryption; public disclosure through leak sites. |
| MITRE ATT&CK Mapping | T1078 Valid Accounts T1003 Credential Dumping T1021 Remote Services T1486 Data Encrypted for Impact T1487 Exfiltration for Extortion |
| Why it Matters to Novacore | Highly active and damaging but uses generic methods that are less tailored to fintech-specific environments. |

## 6. THREAT GROUP COMPARISON

| Threat Group | Target Financial Sector? | Regional Relevance | Uses Phishing? | Uses Malware? | Uses Ransomware? | Relevance to Novacore? |
|---|---|---|---|---|---|---|
| Scattered Spider | Yes | High | Yes | Yes | Yes | Yes |
| BlackCat/ALPHV | Yes | High | Yes | Yes | Yes | Yes |
| FIN7 | Yes | Medium | Yes | Yes | Yes | Limited |
| TA551 (Shathak) | Yes | High | Yes | Yes | Yes | **No** |
| LockBit 3.0 | Yes | High | Yes | Yes | Yes | Yes |

## Top Three Most Relevant Threat Groups

1**. Scattered Spider**: *Specialises in fintech and cloud-native payment providers; active in the UK; uses methods that directly match Novacore's operating model.*
2**. BlackCat / ALPHV**: Causes very high impact through ransomware and data theft; active in UK financial services and often partners with access brokers like Scattered Spider.
3. **LockBit 3.0**: Extremely active across the UK; opportunistic but capable of causing major disruption if basic controls are missing.

These three groups are most relevant because they ***all target financial services, operate in the UK, and use methods aligned with Novacore's systems***. Scattered Spider stands out because it ***actively selects targets like Novacore, rather than attacking broadly or buying access from others.***

## 7. SELECTED THREAT GROUP DEEP DIVE

### Why This Group Was Selected?

Scattered Spider was selected because it meets every key risk criterion:

- ✅ Consistently targets financial organisations and fintechs specifically.
- ✅ Has proven, documented activity in the United Kingdom.
- ✅ Relies heavily on phishing one of Novacore's top exposure areas.
- ✅ Uses information stealers and malware to harvest credentials.
- ✅ Explicitly targets cloud platforms, digital services, and payment infrastructure.
- ✅ Frequently partners with ransomware groups to deliver full extortion attacks.

### Group Background

**Scattered Spider** is a loosely organised but highly skilled cybercriminal network first identified around 2022. It operates primarily as an initial access broker: it breaches organisations, establishes persistent access, and then sells that access or partners with dedicated ransomware operators to carry out the final extortion phase. The group is best known for its advanced social engineering skills and ability to bypass common security controls such as multi-factor authentication. It almost exclusively targets technology-focused organisations, including fintechs, because these firms often use cloud services that are particularly vulnerable to its attack methods.

### Most Relevant TTPs

| Tactic | Technique | Why It Matters to Novacore |
|---|---|---|
| Initial Access | **Phishing:** Spear phishing Link/SMS Phishing | Novacore uses email and SMS heavily for internal and customer communications, |

| | | |
|---|---|---|
| | | these are the groups primary delivery channels. |
| Credential Access | **Modify Authentication Process:** MFA Bypass | Standard MFA solutions widely used by mid-sized firms are often not effective against the methods this group uses. |
| Execution | **User Execution:** Malicious Link or File | Staff and support teams regularly receive communications from customers and partners thereby increasing the risk of accidental interaction with malicious content. |
| Lateral Movement | **Use Valid Accounts & Remote Services** | Once one account is compromised, the group uses legitimate tools to move through cloud platforms and internal systems without triggering basic alerts. |
| Exfiltration & Impact | **Data Exfiltration + Data Encrypted for Impact** | The group harvests sensitive data before handing over access to ransomware operators, creating both data loss and operational disruption risks. |

## 8. FAMOUS ATTACK CASE STUDY

| **Item Details/Attack/Campaign** | Global Cloud and SaaS Provider Campaign |
|---|---|
| **Threat Group** | Scattered Spider (UNC3944) |
| **Target** | Major US-based cloud communications and SaaS platform with thousands of business customers including financial services firms. |
| **Date/Period** | Mid-2022-Early 2023 |

| | |
|---|---|
| **What Happened** | The group targeted staff at the organisation using personalised SMS and email phishing messages impersonating internal IT teams. They used Evilginx2 to capture login credentials and multi-factor authentication session tokens. Attackers then called the company's global helpdesk teams, using gathered information to impersonate staff and request account changes or security resets. Once inside, they accessed internal tools, customer data, and administrative systems, before partnering with the BlackCat ransomware group to deploy encryption tools and issue extortion demands. |

**TTPs Used in the Famous Attack**

| Tactic | Technique | Evidence from the Attack |
|---|---|---|
| Initial Access | Phishing via SMS and Email | Lures claimed to be urgent security alerts or IT messages sent to staff and support teams. |
| Credential Access | MFA Bypass via Session Token Capture | Attackers intercepted complete authentication sessions, allowing them to bypass standard multi-factor requirements. |
| Defence Evasion | Social Engineering of Support Staff | Callers used real employee details and internal terminology to convince helpdesk teams to adjust account security settings. |

**Why This Attack Matters to Novacore**

Novacore uses cloud business tools, relies on helpdesk processes for account management, and communicates heavily via email and SMS, exactly the pattern targeted in this campaign. The attack shows that strong authentication alone is not enough if staff or support processes can be manipulated.

## 9. RECENT PUBLICLY REPORTED ATTACK OR CAMPAIGN

| Item | Details |
|---|---|
| Attack/Campaign | UK Financial Services and Fintech Targeting Campaign |
| Threat Group | Scattered Spider (UNC3944) |
| Target/Sector | UK fintechs, payment providers, and related financial services firms |
| Date/Period | October 2024 – March 2025 |
| Source | National Cyber Security Centre (NCSC) — Threat Advisory: UNC3944 Activity Against UK Financial Services, April 2025 |
| What Happened | The NCSC reported a sustained campaign targeting UK organisations with cloud-first operations. Attackers used a mix of SMS phishing, fake Microsoft 365 and Okta login pages, and targeted social engineering of IT and customer support teams. Several payment processing firms reported attempts to modify payment portal access and extract merchant data. The NCSC confirmed that some victims were later affected by ransomware from groups known to partner with Scattered Spider. |

## TTPs Used in the Recent Attack

| Tactic | Technique | Evidence from the Attack |
|---|---|---|
| Initial Access | Phishing: Spearphishing Link | Lures were tailored to reference UK banking regulation and payment service updates to increase credibility |
| Credential Access | Valid Accounts from Compromised Credentials Stolen accounts were used to access cloud administration portals and customer management systems. | |
| Discovery | Internal System Information Gathering | Attackers researched public staff profiles and company announcements to improve their impersonation accuracy. |

## Comparison with the Famous Attack

| Area | Famous Attack | Recent Attack |
|---|---|---|
| Target | Global technology provider | UK fintech and financial services |
| Initial Access | SMS + email phishing | SMS + email phishing |
| Malware/Tools | Evilginx2, Cobalt Strike | Evilginx2, Lumma Stealer |
| Main TTPs | Phishing, MFA bypass, helpdesk manipulation | Phishing, MFA bypass, helpdesk manipulation |
| Impact | Ransomware deployment + data access | Credential theft + attempted system access |

**Observation**: ***The group's core tactics have remained consistent over time. They have refined their lures to match local UK industry topics and regulations but continue to rely on the same social engineering and authentication-focused approach.***

## 10. RISK ASSESSMENT FOR NOVACORE

**Final Risk Rating:** ***High***

### Likelihood

The likelihood of ***Scattered Spider*** targeting Novacore is **High: because the**

1. The group actively selects fintech and payment processing targets.
2. Activity in the UK financial sector has increased since 2024.
3. Phishing and social engineering remain common, high-volume threats.
4. Cloud and remote working models used by Novacore match the group's preferred environment.
5. Mid-sized organisations are a known priority because they offer high value with typically less mature defence than large banks.

### Impact

If Novacore were successfully attacked, potential impacts will include:

1. Mass theft of staff and customer credentials.
2. Fraudulent transactions and payment manipulation.
3. Breach of customer personal and financial data.
4. Service disruption or system unavailability.
5. Ransomware encryption of core business systems.
6. Breaches of UK GDPR, NIS 2 Directive, and FCA rules leading to regulatory fines.
7. Significant reputational damage and loss of customer and merchant trust.

### Most Exposed Business Areas

1. All staff email and cloud accounts.

2. IT support and helpdesk teams.
3. Customer service and onboarding teams.
4. Payment processing and transaction systems.
5. Digital wallet platform infrastructure.
6. Cloud identity and access management tools.
7. Customer records and transaction databases.

## 11. RECOMMENDATIONS

### Preventive Controls

a. Deploy FIDO2 phishing-resistant multi-factor authentication for all staff and administrator accounts to block MFA bypass methods.
b. Implement strict multi-channel verification for all helpdesk requests including password resets, access changes, and authentication updates.
c. Restrict creation of new inbox rules and email forwarding configurations.
d. Remove or limit default permissions for cloud application access.
e. Disable legacy authentication protocols that bypass modern security controls.
f. Run quarterly phishing and social engineering awareness training with a focus on payment-related lures and IT support impersonation.
g. Patch all public-facing systems and third-party connectors on a strict schedule.

### Detection Controls

a. Monitor for failed or unusual multi-factor authentication attempts.
b. Alert on login attempts from untrusted geographies or devices not seen before.
c. Monitor for new inbox rules, auto-forwarding, or unusual mailbox activity.
d. Flag use of remote administration tools from unmanaged or external locations.
e. Maintain alerts for known malicious domains, IP addresses, and file hashes linked to **Scattered Spider**.
f. Monitor for large or unusual data transfers outside of standard business hours.
g. Track changes to identity settings, access policies, or administrator permissions.

**Response Actions**

a. Block identified malicious domains, IP addresses, and URLs immediately.
b. Quarantine or remove malicious messages and attachments from all mailboxes.
c. Reset credentials for any confirmed or suspected compromised accounts.
d. Isolate affected endpoints or cloud sessions to prevent further spread.
e. Preserve logs and evidence for investigation and regulatory reporting.
f. Notify senior management and legal/compliance teams as soon as a confirmed breach is identified.
g. Report incidents to the NCSC, FCA, or ICO where required under UK law.
h. Activate communication plans for customers and merchants if their data is affected.

## 12. CONCLUSION

***This assessment identifies Scattered Spider as the threat group most likely to target Novacore Financial Services due to its specific focus on fintech and payment providers, active presence in the UK, and attack methods that align closely with Novacore's technology and working practices. A successful attack could lead to serious financial loss, regulatory penalty, and long-term reputational harm.***

***The threat intelligence process demonstrates that generic cybersecurity controls are often not enough against well-resourced and targeted groups. For Novacore, the priority is to harden authentication and support processes while maintaining ongoing awareness of how this group and similar actors evolve their tactics. Implementing the recommendations in this report will substantially reduce exposure and build a more resilient security posture.***

## 13. REFERENCES

1. Threat Advisory: UNC3944 Activity Against UK Financial Services — National Cyber Security Centre, April 2025
Link*: https://www.ncsc.gov.uk*
Used for: Regional activity, TTPs, and recent campaign details
2. MITRE ATT&CK® Framework for Enterprise v14 — MITRE Corporation, 2026

Link*: https://attack.mitre.org*
Used for: Technique definitions and mapping
3. Cyber Threat Profile: UK Fintech Providers — Financial Conduct Authority, June 2025
Link*: https://www.fca.org.uk*
Used for: Sector risk context and regulatory expectations
4. UNC3944: Cloud-Focused Social Engineering and Extortion — Mandiant, August 2024
Link: *https://www.mandiant.com*
Used for: Group background, tactics, and famous attack details
5. Internet Organised Crime Threat Assessment (IOCTA) 2025 — Europol, 2025
Link*: https://www.europol.europa.eu*
Used for: Threat group comparison and European context
6. Ransomware and Extortion Landscape 2026 — National Cyber Security Centre, January 2026
Link: *https://www.ncsc.gov.uk*
Used for: LockBit and BlackCat activity data

## 14. APPENDICES

### Appendix A: Threat Group Profile Evidence

- NCSC threat alert extracts
- Mandiant group profile summaries
- Europol threat overview notes

### Appendix B: MITRE ATT&CK Mapping

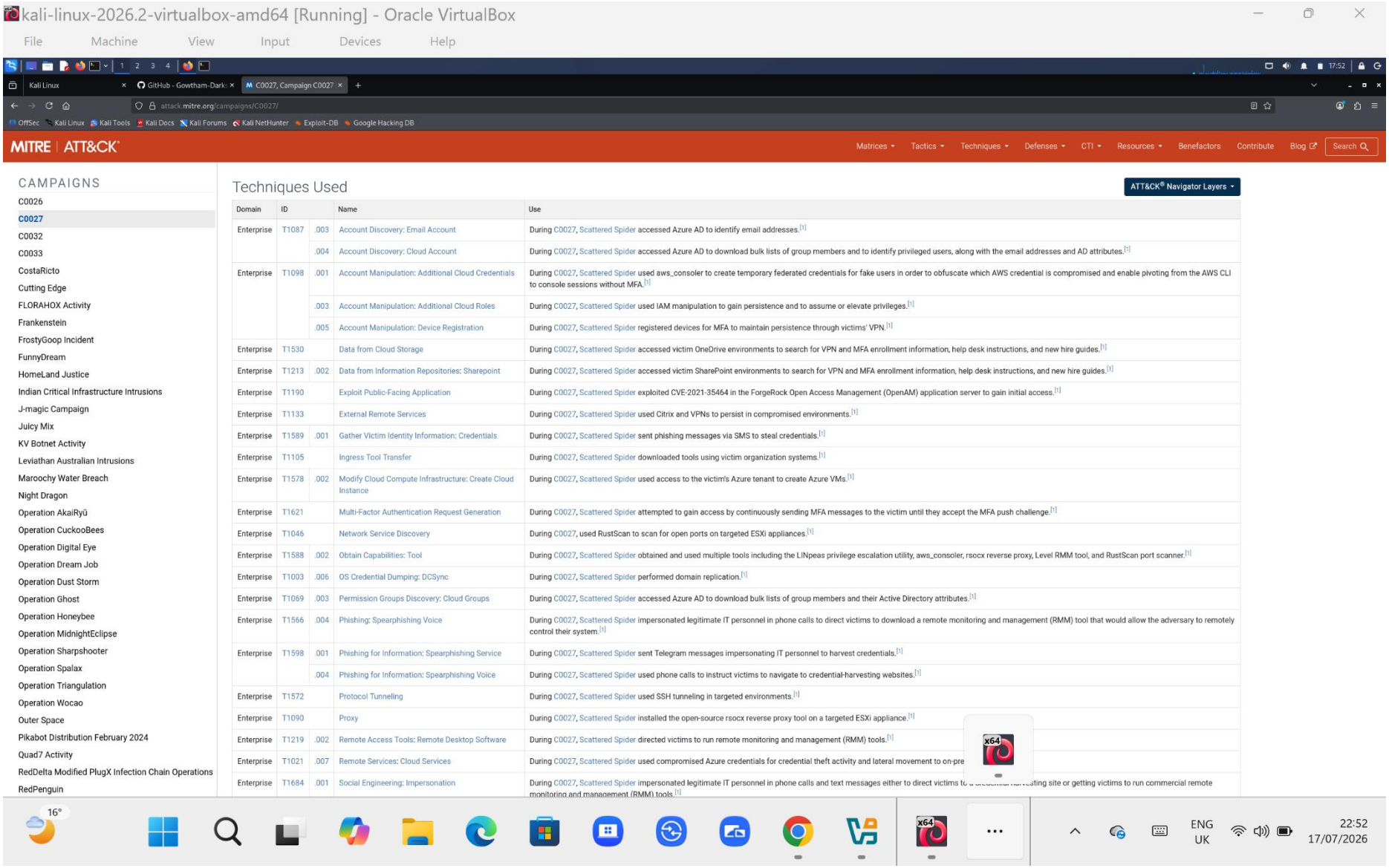
- Full list of techniques observed for each group
- Mapping table including tactic IDs and technique IDs for reference

### Appendix C: Famous Attack Evidence

- Summary of public reporting on the 2022–2023 cloud services campaign
- Extracts from published incident analysis

**Appendix D: Recent Campaign Evidence**

- NCSC April 2025 advisory summary


kali-linux-2026.2-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Kali Linux
GitHub - Gowtham-Dark:
C0027, Campaign C0027
attack.mitre.org/campaigns/C0027/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
MITRE | ATT&CK
Matrices Tactics Techniques Defenses CTI Resources Benefactors Contribute Blog Search
CAMPAIGNS
C0026
C0027
C0032
C0033
CostaRicto
Cutting Edge
FLORAHOX Activity
Frankenstein
FrostyGoop Incident
FunnyDream
HomeLand Justice
Indian Critical Infrastructure Intrusions
J-magic Campaign
Juicy Mix
KV Botnet Activity
Leviathan Australian Intrusions
Maroochy Water Breach
Night Dragon
Operation AkaiRyū
Operation CuckooBees
Operation Digital Eye
Operation Dream Job
Operation Dust Storm
Operation Ghost
Operation Honeybee
Operation MidnightEclipse
Operation Sharpshooter
Operation Spalax
Operation Triangulation
Operation Wocao
Outer Space
Pikabot Distribution February 2024
Quad7 Activity
RedDelta Modified PlugX Infection Chain Operations
RedPenguin
Techniques Used
ATT&CK® Navigator Layers
Domain ID Name Use
Enterprise T1087 .003 Account Discovery: Email Account During C0027, Scattered Spider accessed Azure AD to identify email addresses.
.004 Account Discovery: Cloud Account During C0027, Scattered Spider accessed Azure AD to download bulk lists of group members and to identify privileged users, along with the email addresses and AD attributes.
Enterprise T1098 .001 Account Manipulation: Additional Cloud Credentials During C0027, Scattered Spider used aws_consoler to create temporary federated credentials for fake users in order to obfuscate which AWS credential is compromised and enable pivoting from the AWS CLI to console sessions without MFA.
.003 Account Manipulation: Additional Cloud Roles During C0027, Scattered Spider used IAM manipulation to gain persistence and to assume or elevate privileges.
.005 Account Manipulation: Device Registration During C0027, Scattered Spider registered devices for MFA to maintain persistence through victims' VPN.
Enterprise T1530 Data from Cloud Storage During C0027, Scattered Spider accessed victim OneDrive environments to search for VPN and MFA enrollment information, help desk instructions, and new hire guides.
Enterprise T1213 .002 Data from Information Repositories: Sharepoint During C0027, Scattered Spider accessed victim SharePoint environments to search for VPN and MFA enrollment information, help desk instructions, and new hire guides.
Enterprise T1190 Exploit Public-Facing Application During C0027, Scattered Spider exploited CVE-2021-35464 in the ForgeRock Open Access Management (OpenAM) application server to gain initial access.
Enterprise T1133 External Remote Services During C0027, Scattered Spider used Citrix and VPNs to persist in compromised environments.
Enterprise T1589 .001 Gather Victim Identity Information: Credentials During C0027, Scattered Spider sent phishing messages via SMS to steal credentials.
Enterprise T1105 Ingress Tool Transfer During C0027, Scattered Spider downloaded tools using victim organization systems.
Enterprise T1578 .002 Modify Cloud Compute Infrastructure: Create Cloud Instance During C0027, Scattered Spider used access to the victim's Azure tenant to create Azure VMs.
Enterprise T1621 Multi-Factor Authentication Request Generation During C0027, Scattered Spider attempted to gain access by continuously sending MFA messages to the victim until they accept the MFA push challenge.
Enterprise T1046 Network Service Discovery During C0027, used RustScan to scan for open ports on targeted ESXi appliances.
Enterprise T1588 .002 Obtain Capabilities: Tool During C0027, Scattered Spider obtained and used multiple tools including the LINpeas privilege escalation utility, aws_consoler, rsocx reverse proxy, Level RMM tool, and RustScan port scanner.
Enterprise T1003 .006 OS Credential Dumping: DCSync During C0027, Scattered Spider performed domain replication.
Enterprise T1069 .003 Permission Groups Discovery: Cloud Groups During C0027, Scattered Spider accessed Azure AD to download bulk lists of group members and their Active Directory attributes.
Enterprise T1566 .004 Phishing: Spearphishing Voice During C0027, Scattered Spider impersonated legitimate IT personnel in phone calls to direct victims to download a remote monitoring and management (RMM) tool that would allow the adversary to remotely control their system.
Enterprise T1598 .001 Phishing for Information: Spearphishing Service During C0027, Scattered Spider sent Telegram messages impersonating IT personnel to harvest credentials.
.004 Phishing for Information: Spearphishing Voice During C0027, Scattered Spider used phone calls to instruct victims to navigate to credential-harvesting websites.
Enterprise T1572 Protocol Tunneling During C0027, Scattered Spider used SSH tunneling in targeted environments.
Enterprise T1090 Proxy During C0027, Scattered Spider installed the open-source rsocx reverse proxy tool on a targeted ESXi appliance.
Enterprise T1219 .002 Remote Access Tools: Remote Desktop Software During C0027, Scattered Spider directed victims to run remote monitoring and management (RMM) tools.
Enterprise T1021 .007 Remote Services: Cloud Services During C0027, Scattered Spider used compromised Azure credentials for credential theft activity and lateral movement to on-pre
Enterprise T1684 .001 Social Engineering: Impersonation During C0027, Scattered Spider impersonated legitimate IT personnel in phone calls and text messages either to direct victims to
monitoring and management (RMM) tools.
x64
16°
ENG UK
22:52 17/07/2026

## Techniques Used

ATT&CK® Navigator Layers

| Domain | ID | | Name | Use |
|---|---|---|---|---|
| Enterprise | T1087 | .003 | Account Discovery: Email Account | During C0027, Scattered Spider accessed Azure AD to identify email addresses.[1] |
| | | .004 | Account Discovery: Cloud Account | During C0027, Scattered Spider accessed Azure AD to download bulk lists of group members and to identify privileged users, along with the email addresses and AD attributes.[1] |
| Enterprise | T1098 | .001 | Account Manipulation: Additional Cloud Credentials | During C0027, Scattered Spider used aws_consoler to create temporary federated credentials for fake users in order to obfuscate which AWS credential is compromised and enable pivoting from the AWS CLI to console sessions without MFA.[1] |
| | | .003 | Account Manipulation: Additional Cloud Roles | During C0027, Scattered Spider used IAM manipulation to gain persistence and to assume or elevate privileges.[1] |
| | | .005 | Account Manipulation: Device Registration | During C0027, Scattered Spider registered devices for MFA to maintain persistence through victims' VPN.[1] |
| Enterprise | T1530 | | Data from Cloud Storage | During C0027, Scattered Spider accessed victim OneDrive environments to search for VPN and MFA enrollment information, help desk instructions, and new hire guides.[1] |
| Enterprise | T1213 | .002 | Data from Information Repositories: Sharepoint | During C0027, Scattered Spider accessed victim SharePoint environments to search for VPN and MFA enrollment information, help desk instructions, and new hire guides.[1] |
| Enterprise | T1190 | | Exploit Public-Facing Application | During C0027, Scattered Spider exploited CVE-2021-35464 in the ForgeRock Open Access Management (OpenAM) application server to gain initial access.[1] |
| Enterprise | T1133 | | External Remote Services | During C0027, Scattered Spider used Citrix and VPNs to persist in compromised environments.[1] |
| Enterprise | T1589 | .001 | Gather Victim Identity Information: Credentials | During C0027, Scattered Spider sent phishing messages via SMS to steal credentials.[1] |
| Enterprise | T1105 | | Ingress Tool Transfer | During C0027, Scattered Spider downloaded tools using victim organization systems.[1] |
| Enterprise | T1578 | .002 | Modify Cloud Compute Infrastructure: Create Cloud Instance | During C0027, Scattered Spider used access to the victim's Azure tenant to create Azure VMs.[1] |
| Enterprise | T1621 | | Multi-Factor Authentication Request Generation | During C0027, Scattered Spider attempted to gain access by continuously sending MFA messages to the victim until they accept the MFA push challenge.[1] |
| Enterprise | T1046 | | Network Service Discovery | During C0027, used RustScan to scan for open ports on targeted ESXi appliances.[1] |
| Enterprise | T1588 | .002 | Obtain Capabilities: Tool | During C0027, Scattered Spider obtained and used multiple tools including the LINpeas privilege escalation utility, aws_consoler, rsocx reverse proxy, Level RMM tool, and RustScan port scanner.[1] |
| Enterprise | T1003 | .006 | OS Credential Dumping: DCSync | During C0027, Scattered Spider performed domain replication.[1] |
| Enterprise | T1069 | .003 | Permission Groups Discovery: Cloud Groups | During C0027, Scattered Spider accessed Azure AD to download bulk lists of group members and their Active Directory attributes.[1] |
| Enterprise | T1566 | .004 | Phishing: Spearphishing Voice | During C0027, Scattered Spider impersonated legitimate IT personnel in phone calls to direct victims to download a remote monitoring and management (RMM) tool that would allow the adversary to remotely control their system.[1] |
| Enterprise | T1598 | .001 | Phishing for Information: Spearphishing Service | During C0027, Scattered Spider sent Telegram messages impersonating IT personnel to harvest credentials.[1] |
| | | .004 | Phishing for Information: Spearphishing Voice | During C0027, Scattered Spider used phone calls to instruct victims to navigate to credential-harvesting websites.[1] |
| Enterprise | T1572 | | Protocol Tunneling | During C0027, Scattered Spider used SSH tunneling in targeted environments.[1] |
| Enterprise | T1090 | | Proxy | During C0027, Scattered Spider installed the open-source rsocx reverse proxy tool on a targeted ESXi appliance.[1] |
| Enterprise | T1219 | .002 | Remote Access Tools: Remote Desktop Software | During C0027, Scattered Spider directed victims to run remote monitoring and management (RMM) tools.[1] |
| Enterprise | T1021 | .007 | Remote Services: Cloud Services | During C0027, Scattered Spider used compromised Azure credentials for credential theft activity and lateral movement to on-premises systems.[1] |
| Enterprise | T1684 | .001 | Social Engineering: Impersonation | During C0027, Scattered Spider impersonated legitimate IT personnel in phone calls and text messages either to direct victims to a credential harvesting site or getting victims to run commercial remote monitoring and management (RMM) tools.[1] |

Home > Groups > Scattered Spider

# Scattered Spider

Scattered Spider is a native English-speaking cybercriminal group active since at least 2022. [1] [2] The group initially targeted customer relationship management (CRM) providers, business process outsourcing (BPO) firms, and telecommunications and technology companies before expanding in 2023 to gaming, hospitality, retail, managed service provider (MSP), manufacturing, and financial sectors. [2]

Scattered Spider relies heavily on social engineering, including impersonating IT and help-desk staff, to gain initial access, bypass multi-factor authentication (MFA), and compromise enterprise networks. The group has adapted its tooling to evade endpoint detection and response (EDR) defenses and used ransomware for financial gain. [3] [4] [5]

Scattered Spider had expanded into hybrid cloud and identity environments, using help-desk impersonation and MFA bypass to obtain administrator access in Okta, AWS, and Office 365. [6]

ID: G1015
Associated Groups: Roasted 0ktapus, Octo Tempest, Storm-0875, UNC3944
Version: 3.0
Created: 05 July 2023
Last Modified: 24 October 2025

Version Permalink

## Associated Group Descriptions

| Name | Description |
|---|---|
| Roasted 0ktapus | [4] |
| Octo Tempest | [7] |
| Storm-0875 | [7] |
| UNC3944 | [6][8] |

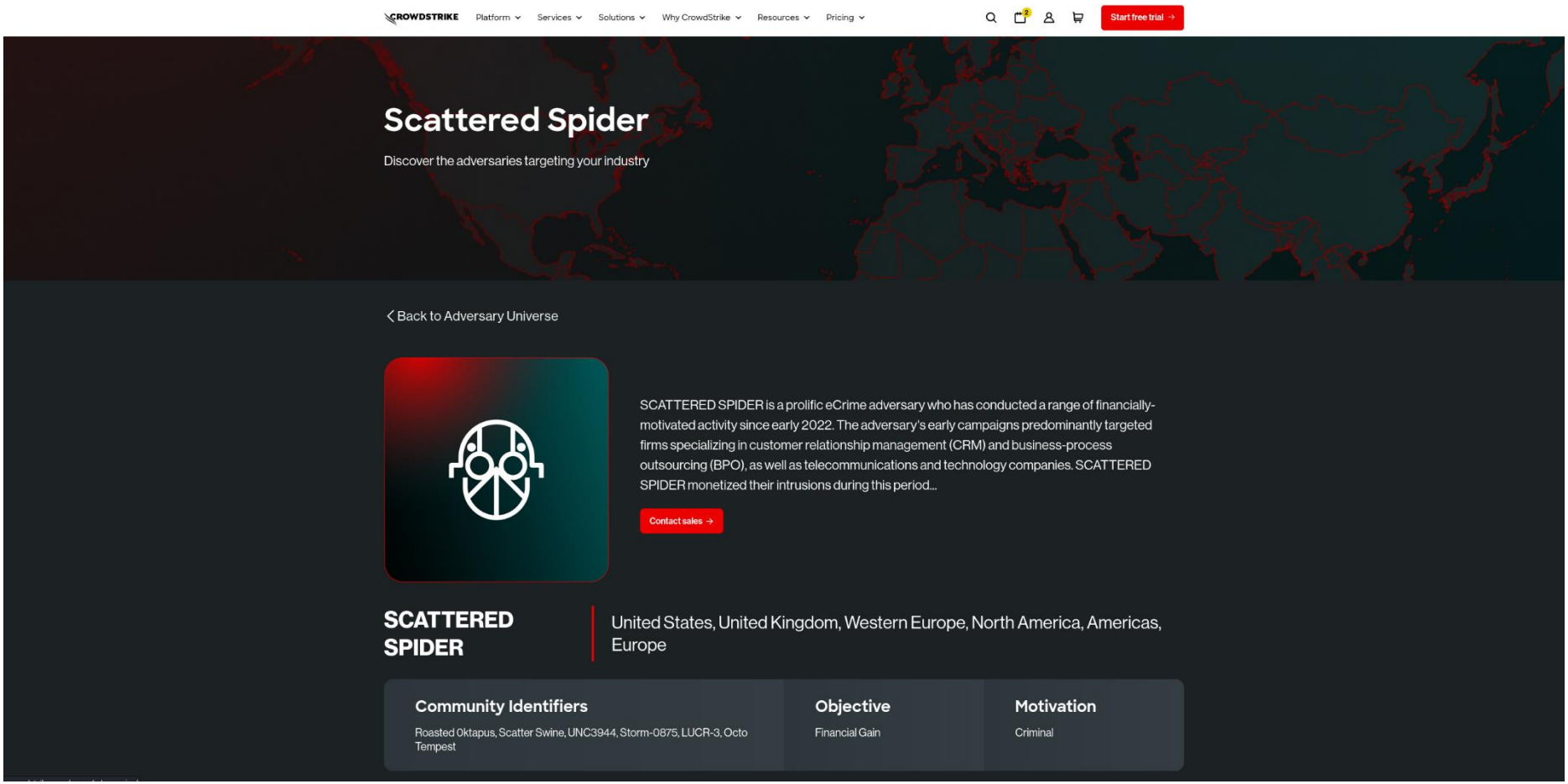
## Campaigns

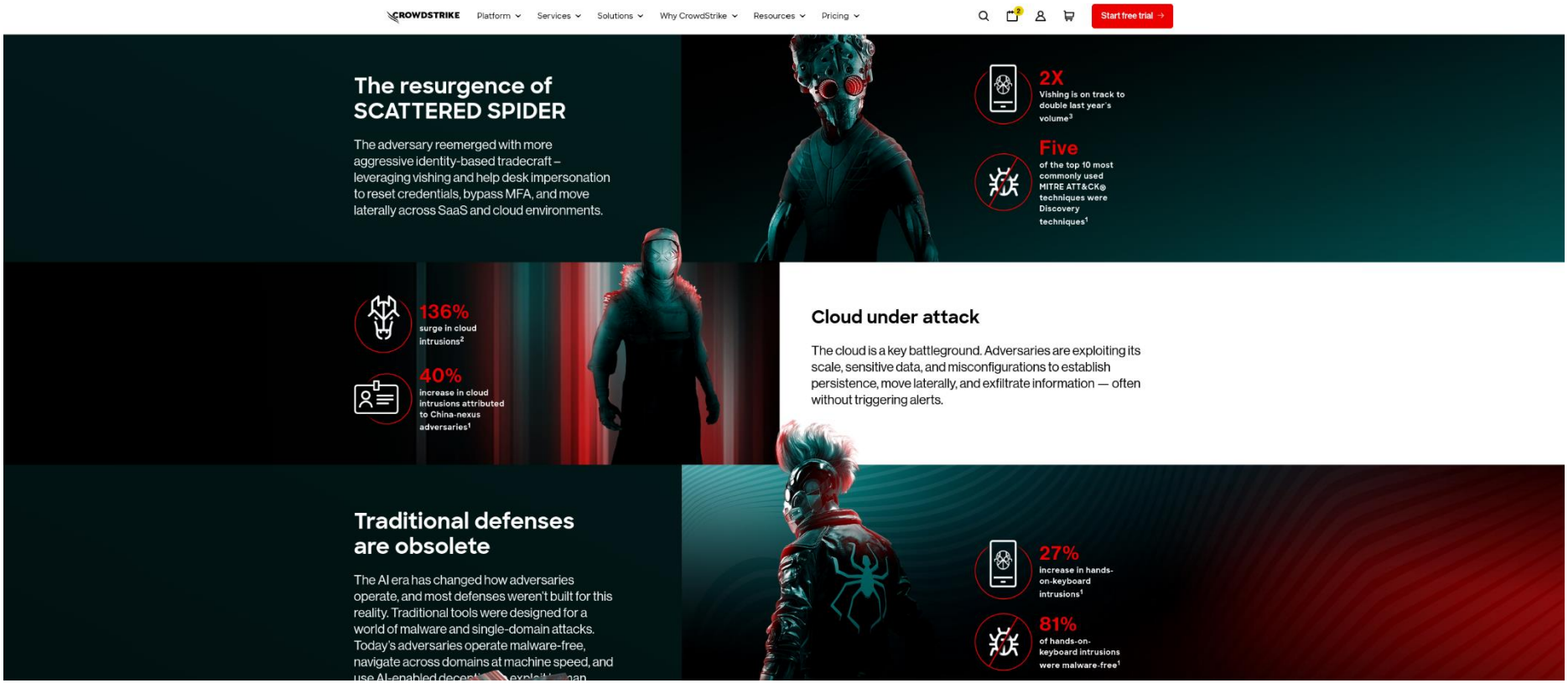
| ID | Name | First Seen | Last Seen | References | Techniques |
|---|---|---|---|---|---|
| C0027 | C0027 | June 2022 [5] | December 2022 [5] | [5] | Account Discovery: Cloud Account, Account Discovery: Email Account, Account Manipulation: Additional Cloud Roles, Account Manipulation: Device Registration, Account Manipulation: Additional Cloud Credentials, Data from Cloud Storage, Data from Information Repositories: Sharepoint, Exploit Public-Facing Application, External Remote Services, Gather Victim Identity Information: Credentials, Ingress Tool Transfer, Modify Cloud Compute Infrastructure: Create Cloud Instance, Multi-Factor Authentication Request Generation, Network Service Discovery, Obtain Capabilities: Tool, OS Credential Dumping: DCSync, Permission Groups Discovery: Cloud Groups, Phishing: Spearphishing Voice, Phishing for Information: Spearphishing Voice, Phishing for Information: Spearphishing Service, Protocol Tunneling, Proxy, Remote Access Tools: Remote Desktop Software, Remote Services: Cloud Services, Social Engineering: Impersonation, Valid Accounts: Cloud Accounts, Web Service, Windows Management Instrumentation |

## Techniques Used

ATT&CK® Navigator Layers

| Domain | ID | Name | Use |
|---|---|---|---|
| Enterprise | T1087 | Account Discovery | Scattered Spider has identified vSphere administrator accounts.[8] |
| | .002 | Domain Account | Scattered Spider has enumerated legitimate domain accounts which are used in the targeted environment.[3][2][9][8] |
| | .003 | Email Account | During C0027, Scattered Spider accessed Azure AD to identify email addresses.[5] |
| | .004 | Cloud Account | During C0027, Scattered Spider accessed Azure AD to download bulk lists of group members and to identify privileged users, along with the email addresses and AD attributes.[5] |
| Enterprise | T1098 | Account Manipulation | Scattered Spider has added accounts to the ESX Admins group to grant them full admin rights in vSphere.[8] |
| | .001 | Additional Cloud Credentials | During C0027, Scattered Spider used aws_consoler to create temporary federated credentials for fake users in order to obfuscate which AWS credential is compromised and enable pivoting from the AWS CLI to console sessions without MFA.[5] |


CROWDSTRIKE
Platform
Services
Solutions
Why CrowdStrike
Resources
Pricing
Start free trial →
Scattered Spider
Discover the adversaries targeting your industry
Back to Adversary Universe
SCATTERED SPIDER is a prolific eCrime adversary who has conducted a range of financially-motivated activity since early 2022. The adversary's early campaigns predominantly targeted firms specializing in customer relationship management (CRM) and business-process outsourcing (BPO), as well as telecommunications and technology companies. SCATTERED SPIDER monetized their intrusions during this period...
Contact sales →
SCATTERED SPIDER
United States, United Kingdom, Western Europe, North America, Americas, Europe
Community Identifiers
Roasted Oktapus, Scatter Swine, UNC3944, Storm-0875, LUCR-3, Octo Tempest
Objective
Financial Gain
Motivation
Criminal


CROWDSTRIKE
Platform
Services
Solutions
Why CrowdStrike
Resources
Pricing
Start free trial
The resurgence of SCATTERED SPIDER
The adversary reemerged with more aggressive identity-based tradecraft – leveraging vishing and help desk impersonation to reset credentials, bypass MFA, and move laterally across SaaS and cloud environments.
2X
Vishing is on track to double last year's volume[3]
Five
of the top 10 most commonly used MITRE ATT&CK® techniques were Discovery techniques[1]
136%
surge in cloud intrusions[2]
40%
increase in cloud intrusions attributed to China-nexus adversaries[1]
Cloud under attack
The cloud is a key battleground. Adversaries are exploiting its scale, sensitive data, and misconfigurations to establish persistence, move laterally, and exfiltrate information — often without triggering alerts.
Traditional defenses are obsolete
The AI era has changed how adversaries operate, and most defenses weren't built for this reality. Traditional tools were designed for a world of malware and single-domain attacks. Today's adversaries operate malware-free, navigate across domains at machine speed, and
27%
increase in hands-on-keyboard intrusions[1]
81%
of hands-on-keyboard intrusions were malware-free[1]

# SCATTERED SPIDER Exploits Windows Security Deficiencies with Bring-Your-Own-Vulnerable-Driver Tactic in Attempt to Bypass Endpoint Security

January 10, 2023 • CrowdStrike Intelligence Team • Threat Hunting & Intel



- In December 2022, CrowdStrike reported on a campaign by SCATTERED SPIDER, targeting organizations within the telecom and business process outsourcing (BPO) sectors with an end objective of gaining access to mobile carrier networks.
- In the weeks since that post, the CrowdStrike Falcon® platform prevented a novel attempt by SCATTERED SPIDER to deploy a malicious kernel driver through a vulnerability (CVE-2015-2291) in the Intel Ethernet diagnostics driver.
- The activity exploits a well known and pervasive deficiency in Windows security that enables adversaries to bypass Windows kernel protections with the Bring-Your-Own-Vulnerable-Driver tactic.

## Techniques Used

ATT&CK® Navigator Layers

| Domain | ID | | Name | Use |
|---|---|---|---|---|
| Enterprise | T1548 | .002 | Abuse Elevation Control Mechanism: Bypass User Account Control | BlackCat can bypass UAC to escalate privileges.[1] |
| Enterprise | T1134 | | Access Token Manipulation | BlackCat has the ability modify access tokens.[1][2] |
| Enterprise | T1087 | .002 | Account Discovery: Domain Account | BlackCat can utilize `net use` commands to identify domain users.[1] |
| Enterprise | T1059 | .003 | Command and Scripting Interpreter: Windows Command Shell | BlackCat can execute commands on a compromised network with the use of `cmd.exe`.[1] |
| Enterprise | T1486 | | Data Encrypted for Impact | BlackCat has the ability to encrypt Windows devices, Linux devices, and VMWare instances.[1] |
| Enterprise | T1491 | .001 | Defacement: Internal Defacement | BlackCat can change the desktop wallpaper on compromised hosts.[1][2] |
| Enterprise | T1685 | .005 | Disable or Modify Tools: Clear Windows Event Logs | BlackCat can clear Windows event logs using `wevtutil.exe`.[1] |
| Enterprise | T1561 | .001 | Disk Wipe: Disk Content Wipe | BlackCat has the ability to wipe VM snapshots on compromised networks.[1][2] |
| Enterprise | T1083 | | File and Directory Discovery | BlackCat can enumerate files for encryption.[1] |
| Enterprise | T1222 | .001 | File and Directory Permissions Modification: Windows Permissions | BlackCat can use Windows commands such as `fsutil behavior set SymLinkEvaluation R2L:1` to redirect file system access to a different location after gaining access into compromised networks.[1] |
| Enterprise | T1490 | | Inhibit System Recovery | BlackCat can delete shadow copies using `vssadmin.exe delete shadows /all /quiet` and `wmic.exe Shadowcopy Delete`; it can also modify the boot loader using `bcdedit /set {default} recoveryenabled No`.[1] |
| Enterprise | T1570 | | Lateral Tool Transfer | BlackCat can replicate itself across connected servers via `psexec`.[1] |
| Enterprise | T1680 | | Local Storage Discovery | BlackCat can enumerate local drives.[1] |
| Enterprise | T1112 | | Modify Registry | BlackCat has the ability to add the following registry key on compromised networks to maintain persistence: `HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanServer\Paramenters`[1] |
| Enterprise | T1135 | | Network Share Discovery | BlackCat has the ability to discover network shares on compromised networks.[1][2] |
| Enterprise | T1069 | .002 | Permission Groups Discovery: Domain Groups | BlackCat can determine if a user on a compromised host has domain admin privileges.[1] |
| Enterprise | T1018 | | Remote System Discovery | BlackCat can broadcasts NetBIOS Name Service (NBNC) messages to search for servers connected to compromised networks.[1] |
| Enterprise | T1489 | | Service Stop | BlackCat has the ability to stop VM services on compromised networks.[1][2] |
| Enterprise | T1082 | | System Information Discovery | BlackCat can obtain the computer name and UUID.[1] |
| Enterprise | T1033 | | System Owner/User Discovery | BlackCat can utilize `net use` commands to discover the user name on a compromised host.[1] |
| Enterprise | T1047 | | Windows Management Instrumentation | BlackCat can use `wmic.exe` to delete shadow copies on compromised networks.[1] |



Threat Research | BlackCat | Citrix | ESXi | Featured | Security Operations | Sophos X-Ops | VMware | vpn

A ransomware group attacking large organizations with malware called BlackCat has followed a consistent pattern over the past several months: The threat actors break in to enterprise networks by exploiting vulnerabilities in unpatched or outdated firewall/VPN devices, then pivot to internal systems after establishing a foothold from the firewall.

Since December 2021, Sophos has been called in to investigate at least five attacks involving this ransomware. In two of the cases, the attackers made their initial access to the target's network by exploiting a vulnerability that was first disclosed in 2018 and affected a particular firewall vendor's product. In two others, the attackers targeted a different firewall vendor's product with a vulnerability that was disclosed last year.

In all but one of the incidents we investigated, the vulnerabilities permitted the attackers to obtain VPN credentials from memory on the firewall devices, which they could then use to log in to the VPN as if they were an authorized user. None of the targets used multifactor authentication for these VPNs. The one outlier appears to have been a spearphishing attack that revealed an internal user's VPN login credentials to the attackers.

Once inside the network, the attackers predominantly used RDP to move laterally between computers, conducting brute-force attacks over the VPN connection against the Administrator account on machines inside the network. The ransomware executable has functionality to spread itself laterally to Windows machines, as well as specific capabilities designed to target VMware ESXi hypervisor servers.

In last year's Annual Review, we spoke about the cyber threat becoming "increasingly diffuse and dangerous". 2025 has seen that trend intensify. We are in a period of sustained international competition, punctuated by multiple acute crises and increasing conflict. Cyber is being used by state and non-state actors to achieve their goals, and the overall cyber threat to the UK is growing from an already high level. The NCSC's incident statistics underline this growing intensity, with nationally significant incidents up by 50%.

Understanding the world we are in, and the role that cyber now plays within crisis and conflict, means we must also shift how we respond. In the face of escalating threat, we must develop the ability to rapidly interpret intent, capability, and geopolitical context across multiple actors in complex environments.

The need for this is increased by the varied ways we see threat actors operate, for the differing purposes of espionage, destruction, influence and leverage. This ranges from core capability and differing intents, from tightly controlled elite units to generating ecosystems of private sector, hacktivism and proxies access.




Pages

NCSC Annual Review 2025